

**INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS
ACADEMY**

Week 2 Practical Laboratory

Module 2 - Developing Security Policies and Procedures

Developing Security Policies and Procedures

NexusTech Solutions Security Policy Development Lifecycle

Student Name: Jackline Maina

Reg. No: C11/26/CGRCE/17588

Course: GRC102 - Information Security Governance

Date: 18/09/2026

Table of Contents

Task 1: Security Policy Hierarchy (20 Marks).....	3
1.1 Hierarchy Definition Table.....	3
1.2 Categorisation Table	4
1.3 Policy Hierarchy Diagram.....	5
Task 2: Acceptable Use Policy (25 Marks)	6
Document Control	6
Purpose	6
Scope.....	6
Policy Statements.....	6
Acceptable Use	6
Prohibited Activities.....	7
Roles and Responsibilities.....	7
Compliance and Enforcement	7
Exceptions.....	7
Approval and Review	7
Task 3: User Access Request Procedure (20 Marks).....	8
Purpose	8
Scope	8
Prerequisites	8
Procedure	8
Emergency Requests	9
Record Retention.....	9
Task 4: Communication and Training Plan (20 Marks).....	10
Communication and Training Plan	10
Rollout Timeline	11
Escalation.....	11
Task 5: Policy Review and Maintenance Memo (15 Marks).....	12
References.....	13

Task 1: Security Policy Hierarchy (20 Marks)

This section establishes the security documentation hierarchy and classifies NexusTech's draft security statements according to their appropriate document type.

1.1 Hierarchy Definition Table

Document Type	Purpose	Authority	Mandatory/Recommended	Level of Detail
Policy	Defines management intent and security requirements	Executive Management	Mandatory	High-level
Standard	Defines mandatory technical or operational requirements	Policy Owner/CISO	Mandatory	Detailed
Procedure	Provides step-by-step instructions for implementing standards and policies	Process Owner	Mandatory	Very Detailed
Guideline	Provides recommended best practices and advice	Subject Matter Experts	Recommended	Flexible

1.2 Categorisation Table

Statement	Classification	Justification
MFA required for remote access	Policy	Defines a mandatory organizational requirement.
Download Authenticator app and scan QR code	Procedure	Provides step-by-step implementation instructions.
Developers should use parameterised queries	Guideline	Recommends a security best practice.
NexusTech is committed to protecting CIA of client data	Policy	States management intent and direction.
Laptops must have BitLocker or FileVault enabled	Standard	Defines a specific mandatory security control.
Employees should avoid public Wi-Fi	Guideline	Recommended behavior, not mandatory.
Contact Helpdesk at extension 5555 during incidents	Procedure	Specifies actions to perform.
Passwords must be 14 characters with complexity requirements	Standard	Defines mandatory technical requirements.

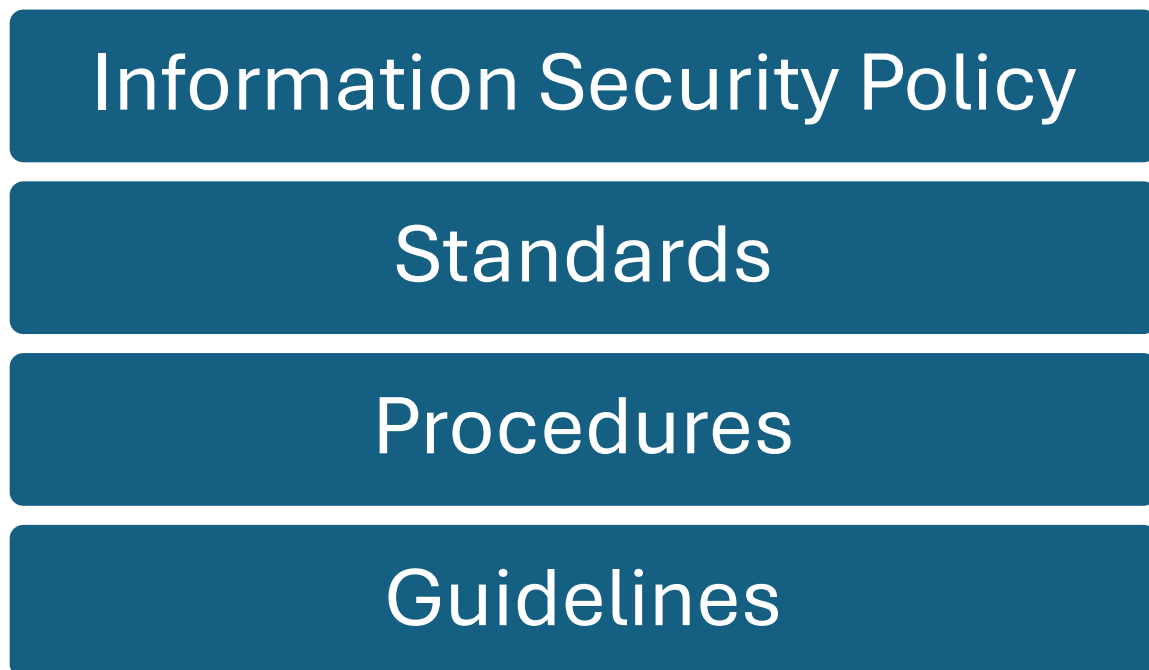
1.3 Policy Hierarchy Diagram

Introduction

NexusTech shall maintain a structured policy framework to ensure consistency, accountability, and effective implementation of security requirements.

Policies establish organizational security direction, standards define mandatory requirements, procedures provide implementation instructions, and guidelines provide recommended best practices that support consistent implementation.

Figure 1: NexusTech Security Documentation Hierarchy



Task 2: Acceptable Use Policy (25 Marks)

This section presents the Acceptable Use Policy developed for NexusTech to establish acceptable and prohibited use of organizational resources.

Document Control

Field	Details
Title	Acceptable Use Policy
Version	1.0
Policy Owner	Information Security Manager
Approval Authority	Marcus Vance, CEO
Effective Date	18 September 2026
Review Date	18 September 2027

Purpose

To define the acceptable and secure use of NexusTech information systems, devices, networks, and information assets.

Scope

Applies to all employees, contractors, consultants, temporary staff, and third parties using NexusTech resources.

Policy Statements

Acceptable Use

- Company resources shall be used primarily for authorized business purposes.
- Users shall protect credentials and sensitive information.
- Users shall comply with all security policies and standards.
- Reasonable personal use is permitted provided it does not interfere with business operations.

Prohibited Activities

- Password sharing is prohibited.
- Unauthorized software installation is prohibited.
- Accessing illegal, offensive, or inappropriate content is prohibited.
- Circumventing security controls is prohibited.
- Downloading unlicensed software is prohibited.
- Using company systems for personal commercial activities is prohibited.

Roles and Responsibilities

Users

- Comply with the policy.
- Report security incidents.

IT and Security

- Monitor compliance.
- Investigate violations.

Managers

- Ensure team awareness and compliance.

HR

- Support disciplinary actions where necessary.

Compliance and Enforcement

Failure to comply with this policy may result in access restrictions, disciplinary action, termination of employment, or legal action where applicable.

Exceptions

Exceptions require documented business justification, risk assessment, and approval by the Information Security Manager.

Approval and Review

Approved by Marcus Vance, CEO. Reviewed annually.

Task 3: User Access Request Procedure (20 Marks)

This section outlines the User Access Request Procedure used to ensure authorized and properly documented access to NexusTech systems.

Purpose

To ensure all user access requests are authorized, provisioned, documented, and reviewed in a consistent and auditable manner.

Scope

Applies to all NexusTech systems and applications.

Prerequisites

- Approved access request ticket
- Manager approval
- Data owner approval where applicable

Procedure

Step 1: Request Submission

The requester submits an access request through the approved ticketing system.

Step 2: Approval Verification

The Helpdesk verifies:

- Manager approval
- Data owner approval (where applicable)

Step 3: Access Validation

The Helpdesk confirms:

- Business need
- Appropriate role
- Least privilege requirements

Step 4: Account Creation

Create the user account following approved provisioning procedures.

Step 5: Permission Assignment

Assign permissions using approved role-based access profiles.

Step 6: User Notification

Notify the user and manager when access has been granted.

Step 7: Evidence Capture

Attach approvals, screenshots, and supporting evidence to the ticket.

Step 8: Ticket Closure

Document all actions and close the ticket.

Emergency Requests

Emergency access requires manager approval and retrospective review within 24 hours.

Record Retention

Access request records, approvals, and associated audit evidence shall be retained for a minimum of three years.

Task 4: Communication and Training Plan (20 Marks)

This section presents the communication and training plan for the rollout of the Acceptable Use Policy.

Communication and Training Plan

Effective communication and training are essential to ensure that employees understand and comply with the new Acceptable Use Policy. The following plan outlines the communication approach, stakeholder responsibilities, rollout activities, and measures of effectiveness.

Audience	Key Message	Channel	Owner	Timing	Acknowledgement	Success Measure
Employees	Acceptable use requirements are mandatory	Email, LMS	Security Manager	Week 1	Policy attestation	95% completion
IT Staff	Access and enforcement responsibilities	Workshop	Security Manager	Week 1	Attendance register	100% attendance
Management	Compliance oversight responsibilities	Management briefing	Security Manager	Week 1	Meeting sign-off	100% attendance

Rollout Timeline

Week	Activity
Week 1	CEO announcement
Week 1	Policy publication
Week 2	Employee training
Week 3	Policy acknowledgement
Week 4	Compliance review

Escalation

- Failure to complete mandatory training after two reminders shall be escalated to the employee's line manager for follow-up.
- Repeated violations are escalated to HR and executive management.

Task 5: Policy Review and Maintenance Memo (15 Marks)

This section provides a policy review memorandum addressing recent business and technology changes affecting the Acceptable Use Policy.

To: Information Security Steering Committee

From: Information Security Manager

Subject: Acceptable Use Policy Review Recommendation

The recent migration of NexusTech's primary database to AWS and the incident involving the sharing of sensitive information through a personal cloud storage account represent significant policy review triggers requiring reassessment of the current Acceptable Use Policy.

The AWS migration introduces new cloud usage and data protection considerations, while the incident highlights gaps in employee understanding of approved data-sharing methods.

It is recommended that the policy review include stakeholder consultation, analysis of the incident findings, review of cloud security requirements, and verification of alignment with regulatory and client obligations. Two proposed policy updates are: (1) explicitly prohibiting the storage or sharing of company information using unauthorized cloud services, and (2) strengthening requirements related to cloud-based data handling and approved collaboration platforms.

The Information Security Manager should remain the policy owner, with approval provided by the CEO and the Information Security Steering Committee. The policy should undergo formal review annually, with early reviews triggered by significant technology changes, major incidents, regulatory requirements, or new business risks.

References

Center for Internet Security. (2024). *CIS critical security controls version 8*.
<https://www.cisecurity.org/controls>

International Cybersecurity and Digital Forensics Academy. (2026). *GRC102 Week 2 course materials: Developing security policies and procedures*. ICDFA.

International Organization for Standardization. (2022). *ISO/IEC 27001:2022 information security, cybersecurity and privacy protection - Information security management systems - Requirements*. ISO.

International Organization for Standardization. (2022). *ISO/IEC 27002:2022 information security, cybersecurity and privacy protection - Information security controls*. ISO.

ISACA. (2019). *COBIT 2019 framework: Governance and management objectives*. ISACA.

National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations (NIST SP 800-53 Rev. 5)*. U.S. Department of Commerce. <https://csrc.nist.gov>

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. U.S. Department of Commerce.